



CANARY

DEFENSIVE CYBERSECURITY PLATFORM

DOCUMENTO TÉCNICO OFICIAL

Manual Completo del Sistema & Arquitectura Defensiva

Guía explicativa integral sobre el funcionamiento del **Auditor SAST Asistido por Inteligencia Artificial** y el **Escudo Guardián 24/7 (WAF Reverse Proxy)** para la protección perimetral de sitios web y APIs.

• Auditoría Estática de Código (SAST)

• Auto-Parchado con Diff Interactivo

• Conexión e Inspección GitHub

• WAF Reverse Proxy 24/7 en Vivo

• Monitor de Integridad (FIM SHA-256)

• Protocolo de Honestidad IA

Plataforma: CANARY Sentinel Core
Autoría: Equipo de Ciberseguridad Defensiva

Versión: 1.0.0 (Producción)
Fecha: Septiembre 2026

1. ¿Qué es CANARY y cuál es su propósito?

CANARY es un ecosistema defensivo de ciberseguridad diseñado para proteger aplicaciones y sitios web en dos momentos críticos: **antes de salir a producción** (auditando el código fuente en busca de vulnerabilidades) y **después de salir a producción** (vigilando e interceptando ciberataques en tiempo real las 24 horas del día).

¿Por qué el nombre CANARY?

Históricamente, los mineros de carbón bajaban con un canario en una jaula. Debido a su sensibilidad biológica, el canario alertaba ante la presencia del más mínimo gas letal antes de que fuera percibido por los humanos. Del mismo modo, **CANARY detecta amenazas ocultas en el código y en el tráfico web** antes de que puedan comprometer los datos de tus clientes.

2. Arquitectura General en Dos Fases

El sistema opera mediante dos anillos de protección desacoplados y complementarios:



CAPA	TECNOLOGÍA / MÓDULO	FUNCIÓN PRINCIPAL	BENEFICIO INMEDIATO
Auditoría Estática	Motor SAST Regex + Parser AST	Escaneo sintáctico y semántico del código fuente	Encuentra fallos antes del despliegue
Remediación IA	Motor Semántico + Orquestador LLM	Generación de diagnóstico pedagógico y parches	El usuario repara el fallo con un clic
Inspección Git	GitHub REST API Client	Exploración y escaneo global de repositorios	Auditoría masiva sin clonar proyectos
Perímetro 24/7	WAF Reverse Proxy (HTTP/SSE)	Pasarela de filtrado bidireccional en tiempo real	Cero cambios de código para el cliente
Integridad (FIM)	SHA-256 File Cryptographic Watcher	Monitoreo continuo de cambios no autorizados	Detecta inserción de webshells al instante

3. Módulo 1: Auditor SAST & Auto-Parchador con IA

El módulo de **Análisis Estático de Seguridad (SAST)** permite pegar cualquier fragmento de código fuente o cargar archivos desde el ordenador para someterlos a una inspección minuciosa.

Vulnerabilidades Detectadas de Acuerdo con OWASP y CWE

- **Inyección SQL (SQLi - CWE-89)**: Localiza concatenaciones directas de cadenas de texto dentro de consultas de bases de datos que permitirían a un atacante alterar la lógica del sistema o vaciar tablas.
- **Cross-Site Scripting (XSS - CWE-79)**: Detecta inyecciones en el DOM mediante `innerHTML`, `document.write()` o variables no saneadas que facultan el robo de cookies y sesiones.
- **Salto de Directorio (Path Traversal / LFI - CWE-22)**: Identifica lecturas de archivos en el servidor (ej. `fs.readFile`) donde la ruta se concatena directamente con parámetros de entrada del usuario sin normalizar ni validar contra rutas permitidas.
- **Ejecución Remota de Código (RCE - CWE-78 / CWE-94)**: Alerta sobre el uso peligroso de funciones de consola como `child_process.exec()` o intérpretes dinámicos como `eval()`.
- **Secretos y Credenciales en Texto Plano (Hardcoded Secrets - CWE-798)**: Identifica contraseñas de bases de datos, tokens JWT y claves privadas quemadas directamente en el código.

El Ciclo de Asistencia con IA: Diagnóstico, Parche y Honestidad

1. Explicación Didáctica (Diagnóstico Pedagógico)

Al presionar *"Explicar con IA"*, la inteligencia artificial genera un reporte estructurado explicando con claridad humana qué es la vulnerabilidad, cuál es el impacto en el negocio y la recomendación técnica estándar para solucionarla.

2. Auto-Parchado con Diff Interactivo

Al presionar *"Parche con IA"*, el sistema presenta un comparador visual que contrasta exactamente qué líneas se eliminan (rojo) y qué líneas seguras se agregan (verde):

```
- const query = "SELECT * FROM users WHERE user = '" + req.body.user + "';";  
+ const query = "SELECT * FROM users WHERE user = $1;";  
+ const result = await db.query(query, [req.body.user]);
```

El botón **"Aplicar Parche al Editor"** reemplaza automáticamente el código vulnerable por el código saneado sin que el usuario tenga que escribirlo manualmente.

3. Protocolo de Honestidad y Transparencia

Cuando el código contiene una contraseña quemada, la IA **nunca inventa claves falsas**. En su lugar, despliega un aviso pedagógico indicando que las credenciales no deben adivinarse ni guardarse en el código, instruyendo al desarrollador sobre cómo moverlas a un archivo `.env` seguro con `process.env`.

4. Módulo 2: Inspección de Repositorios Git (GitHub Connect)

Este módulo permite analizar proyectos alojados en GitHub con total fluidez:

- **Conexión Ágil:** Basta ingresar la URL del repositorio (ej. `https://github.com/usuario/mi-web`) o su identificador (`usuario/repo`). Para repositorios privados, se puede suministrar un Personal Access Token con permisos de sólo lectura (`contents:read`).
- **Explorador Inteligente:** Clasifica de inmediato cuáles archivos son auditable (código fuente) y cuáles son recursos estáticos o documentación.
- **Auditoría Global (Batch Scan):** El botón "Auditar Todo el Repositorio" ejecuta el motor SAST en paralelo sobre todos los archivos del proyecto, produciendo un **Índice de Salud Global (de 0 a 100)** y una lista priorizada de archivos afectados.

5. Módulo 3: Guardián 24/7 (WAF Reverse Proxy Activo)

El Guardián 24/7 es el núcleo de defensa perimetral en tiempo real. Funciona como un **WAF Pasarela (Reverse Proxy)** que se sitúa entre Internet y el servidor real de tu cliente.



¿Cómo se protege una web real sin modificar su código?

1. El usuario registra el nombre de la web y la URL de su servidor (ej. `http://localhost:8080` o `https://mi-tienda.com`).
2. CANARY genera al instante una **URL Pasarela Protegida** (ej. `http://localhost:3000/shield/site_123/`).
3. El cliente apunta su tráfico hacia esta URL pasarela.
4. **Si la petición es limpia:** El proxy la reenvía intacta al servidor del cliente y le devuelve la respuesta original (HTTP 200).
5. **Si la petición contiene un ataque (SQLi, XSS, Path Traversal, RCE):** La pasarela la intercepta en menos de 5 milisegundos, devuelve un **HTTP 403 Forbidden** y registra el incidente en el SOC en vivo sin que el servidor del cliente sufra daño alguno.

File Integrity Monitoring (FIM con SHA-256)

El sistema calcula periódicamente el hash criptográfico SHA-256 de los archivos esenciales. Si un atacante lograse acceder al disco e inyectar un script o webshell, el hash cambia y el panel emite una alerta inmediata de compromiso de integridad.

6. Módulo 4: Simulador de Ciberataques

Permite comprobar la efectividad del Guardián 24/7 disparando sondas controladas en tiempo real:

SIMULACIÓN	CARGA ENVIADA (*PAYLOAD*)	COMPORTAMIENTO ESPERADO
Inyección SQL (SQLi)	' OR '1'='1'--	HTTP 403 Bloqueado Interceptado por filtro SQLi
Inyección XSS	<script>document.location=...</script>	HTTP 403 Bloqueado Interceptado por filtro XSS
Salto de Directorio (LFI)	../../../../etc/passwd	HTTP 403 Bloqueado Interceptado por filtro Traversal
Comandos de Consola (RCE)	127.0.0.1; cat /etc/shadow	HTTP 403 Bloqueado Interceptado por filtro Shell RCE
Escáner Hostil (Bot)	User-Agent: sqlmap/1.7.2#stable	HTTP 403 Bloqueado Neutralizado por filtro de reputación

7. Módulo 5: Configuración Modular de Inteligencia Artificial

El sistema cuenta con un conector multimodelo desacoplado:

- **Modo Local (Listo de Fábrica):** No requiere claves de API ni costo alguno. Realiza el diagnóstico semántico y genera parches de seguridad de forma instantánea.
- **Conexión a OpenAI:** Permite ingresar tu clave `sk- ...` para conectar modelos como `gpt-4o` o `gpt-4o-mini`.
- **Conexión a Google Gemini:** Permite utilizar modelos de última generación como `gemini-1.5-pro` y `gemini-1.5-flash`.
- **API Personalizada:** Soporta endpoints locales compatibles con OpenAI (como Ollama, LocalAI o vLLM) para entornos con privacidad estricta.

8. Guía Rápida de Ejecución y Comandos

Comandos de Terminal para Operar CANARY

```
# 1. Iniciar el servidor principal de CANARY (Puerto 3000)
npm start

# 2. Iniciar el servidor de demostración de tienda web de cliente (Puerto 8080)
node src/samples/customer-live-web.js

# 3. Ejecutar la suite completa de pruebas unitarias automatizadas
npm test
```

Resumen de Acceso a la Interfaz Gráfica

Una vez iniciado el servidor, ingresa en cualquier navegador moderno a:

➡ **`http://localhost:3000`**